



FACHPRÄSENTATION

KI-Plattformen für regulierte Hochsicherheitsumgebungen

Integration, Delivery und Betrieb · Fallbeispiel monti

Luca Leon Happel · Principal Systems Architect & Core Developer, monti

Ideenwettbewerb der HHU 2023

hhu.

Finale Ideenwettbewerb 2023

Ausgezeichnete Gründungsideen

Etwas, das es so noch nicht gibt: Studierende und Forschende der HHU haben erstaunliche Einfälle und wollen sie umsetzen. Das zeigte der diesjährige Ideenwettbewerb des Center for Entrepreneurship Düsseldorf (CEDUS) aufs Neue. Beim großen Finale am 13. Juli setzten sich durch: Ein innovatives Testverfahren für Pilzvergiftungen, ein effizientes Düngeverfahren mit Phosphor, ein Begleitservice für Streaming-Filme, der Einsatz von KI-basierten Tools in der Krebstherapie und bei Hirnaneurysmen sowie die Entwicklung eines neuen Medikaments zur Verbesserung der Herzfunktion nach einem Herzinfarkt.



Gruppenbild der Siegerteams des 12. HHU Ideenwettbewerbs 2023 (alle Fotos: CEDUS)

2x Platz 1

- Platz 1 in der Kategorie Forschende
- Platz 1 beim Publikumspreis

Quelle: HHU, Fotos: CEDUS

TEAM MONTI

Zwei erste Plätze



Fallbeispiel monti: KI auf hochsensiblen Daten

Gesundheitsdaten als kontinuierlicher Datenstrom, ausgewertet von eigenen KI-Modellen. Produktiv seit 2022.

3

regulierte
Großkunden

~150

Nutzer:innen
parallel

~10 GB

pro Nutzer:in und
Tag

1,84 M€

Fördermittel

Principal Systems Architect & Core Developer

Architektur, Großteil von Backend und App, Teile der KI, Betrieb



Anforderungen regulierter Hochsicherheitskunden

Datenhoheit

keine Daten an Dritte, auch
nicht für KI

Abgeschottete Netze

DMZ, Proxys, PKI, Freigaben

Regulatorik

DSGVO · BSI · ISO 27001

Fremdsysteme

Hersteller-SDKs, proprietäre
Formate

Nachweisbarkeit

jede Änderung auditierbar

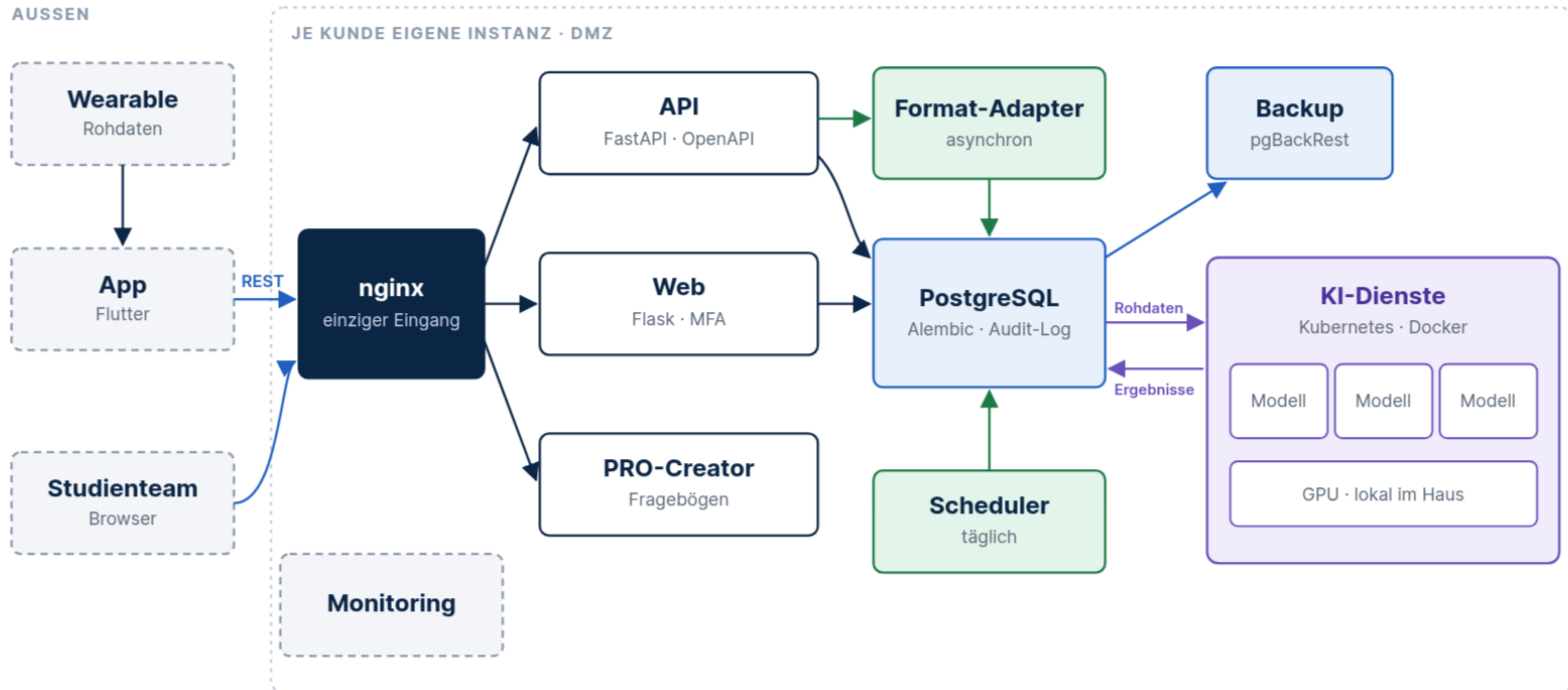
Verfügbarkeit 24/7

Ausfall = Datenverlust

BEI EUCH

dieselben Anforderungen: DORA, AzTech-Freigaben, Landing Zone

Systemarchitektur je Kundeninstanz



KI-Betrieb on-premises



Warum lokal

keine sensiblen Daten an externe KI-APIs

Wie

Docker-Container, gesteuert per Kubernetes

Wo

DMZ UKD · DMZ UKA · GPU-Cluster HHU

BEI EUCH

Bedrock, SageMaker oder eigene Modelle? Inklusive DORA-Drittparteienrisiko

Vier Integrationsmuster

API-First

OpenAPI-Vertrag, Client generiert. Brüche fallen im Build auf.

FRP / Event-driven

Datenverarbeitung mittels Streams.

Asynchron verarbeiten

Upload sofort quittiert, Parsing im Hintergrund.

Versioniertes Schema

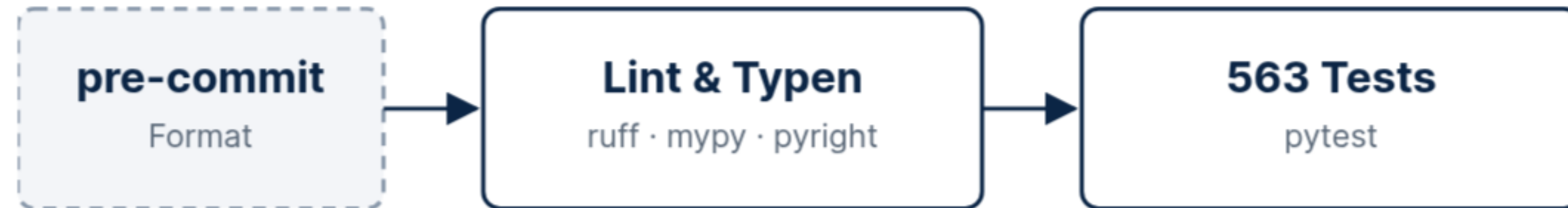
Änderungen nur per Alembic-Migration.

ÜBERTRAG

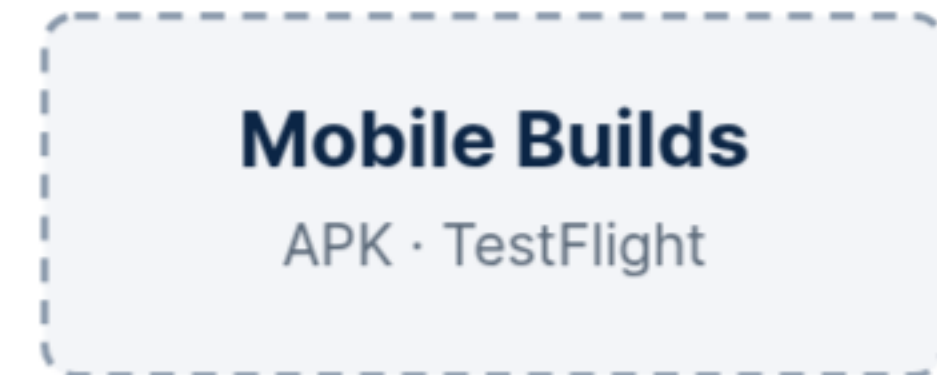
Vertrag statt Absprache, Adapter vor ABS, asynchron für KI-Jobs

CI/CD-Pipeline mit Health-Gates

JEDER PUSH



APP



JEDER PULL REQUEST



Feature → **dev** → **master** · Migrationen automatisch beim Start

Drei regulierte Großkunden im Produktivbetrieb



Universitätsklinikum Düsseldorf

eigene Instanz



**Heinrich-Heine-Universität
Düsseldorf**

eigene Instanz



Uniklinik RWTH Aachen

eigene Instanz

Fotos: Wikimedia Commons · ZOM UKD: EinAnonymerBenutzerVonVielen, CC BY-SA 4.0 · ULB Düsseldorf: gemeinfrei · Klinikum Aachen: Choinowski, CC BY-SA 4.0

Backup, Monitoring, Härtung

Backup

- pgBackRest, WAL-Archiv
- verschlüsselt
- Point-in-Time-Recovery

Monitoring

- Netdata
- Uptime-Kuma
- Health-Endpoint

Härtung

- TLS 1.3, strikte CSP
- MFA für Web und SSH
- Audit-Log, Löschfristen

IN AWS

RDS-PITR · CloudWatch · IAM · Security Groups

Bewährte Muster und Verbesserungen

2025

Xcode 16 bricht das Hersteller-SDK: drei Monate keine Releases. SDK selbst repariert, Backend unberührt.

Bewährt

- Fremdsysteme hinter Adaptern
- Vertrag zuerst, Client generiert
- ganzer Stack in der CI

Heute anders

- Queue statt In-Process-Task
- Secret-Manager statt `.env`
- versionierte Images als Release

DANKE

Fragen?

MEINE ERSTEN 90 TAGE

- Pipelines und Freigabewege verstehen
- ABS-Zugriff über OneDIA kennenlernen
- Referenz-Integration für einen KI-Dienst
- daraus Vorlagen fürs Team

MEINE FRAGEN AN EUCH

- Wie kommt Code heute in Produktion?
- Wie arbeiten Integration und DevOps zusammen?
- Wo hakt es zwischen Data Science und Betrieb?
- Wie laufen KI-Dienste heute?

Container-Stack als Code

```
# docker-compose.yaml (vereinfacht)
x-templates:
  base-python-app: &base-python-app
    user: "${UID}:${GID}"      # kein root
    restart: always
    logging: *logging        # Rotation
    environment: *proxy-env  # Kliniknetz

services:
  api:
    <<: *base-python-app
    ports: ["127.0.0.1:8000:8000"]
    depends_on:
      database:
        condition: service_healthy
  database:
    healthcheck:
      test: pg_isready ...
```

- Templates als Team-Standard
- nur nginx nach außen offen
- Healthchecks statt Sleep
- Proxy in Build und Laufzeit

Compliance im Betrieb

BSI-Grundschutz-Bausteine

APP.3.1 Webanwendungen

APP.3.2 Webserver

OPS.1.1.2 IT-Administration

OPS.1.1.3 Patch & Änderung

OPS.1.1.4 Schadprogramme

ORP.4 Identitäten & Rechte

SYS.1.1 Server

Dokumentiert und gelebt

- Berechtigungskonzept
- Patch- und Änderungsmanagement
- Datenschutz-Folgenabschätzung
- regelmäßige Prüfungen

BEI EUCH

DORA: IKT-Risikomanagement, Änderungsnachweise, Resilienztests

Nix und Terraform

Gemeinsam

- Soll-Zustand im Repo
- Versionen gepinnt (Lock-Datei)
- Änderungen nur per Review

Anders

- Terraform: externe Ressourcen, State, Drift
- Nix: Umgebungen und Systeme
- neu für mich: Remote State, AWS-Provider